

Cybersecurity Risk Assessment & Security Audit

NovaMart (Pvt) Ltd

Portfolio Project

Junior Cybersecurity Analyst - Security Audit

Prepared: September 2026

Purpose

This portfolio project demonstrates a structured security audit of a fictional retail organization. It identifies important assets, evaluates cybersecurity risks, assesses suitable security controls, and provides prioritized recommendations based on confidentiality, integrity, and availability.

Note: NovaMart (Pvt) Ltd is a fictional company created for cybersecurity learning and portfolio demonstration.

1. Executive Summary

NovaMart (Pvt) Ltd is a fictional small electronics retailer with approximately 35 employees and around 5,000 customers. Its environment includes Windows workstations, company Wi-Fi, a public e-commerce website, customer and order data, cloud file storage, employee accounts, a router/firewall, CCTV, and a privileged administrator account.

The audit identified six notable security risks. Four were assessed as Critical and two as High. The most important concerns include weak privileged-account authentication, inadequate backup separation, excessive cloud-file permissions, phishing exposure, unpatched Windows systems, and shared Wi-Fi credentials.

The recommended response is to strengthen administrator authentication, maintain separate recoverable backups, apply least-privilege access, patch systems regularly, improve phishing awareness, and improve network-access management.

Audit Objective

Identify cybersecurity weaknesses, consider their potential effect on NovaMart's information and operations, and recommend practical controls that improve confidentiality, integrity, and availability.

Risk Rating Method

This project uses qualitative ratings of **Low**, **Medium**, **High**, and **Critical**. Likelihood and impact are considered together to determine the overall risk level.

2. Scope and Security Objectives

Systems and assets included in scope:

25 Windows computers; company Wi-Fi/network; public e-commerce website; customer and order database; cloud file storage; employee accounts; administrator account; office router/firewall; CCTV; and sensitive customer and company information.

Information Requiring Protection

Customer names, email addresses, phone numbers and order information; employee information; authentication information; business documents; system and configuration information; and database records.

CIA Triad Objectives

Security Objective	Application to NovaMart
Confidentiality	Sensitive information should only be accessible to authorized users.
Integrity	Records and systems should be protected from unauthorized modification.
Availability	The website, database, network, and business systems should remain available when needed.

3. Asset Inventory and Classification

Asset	Category	Criticality
Customer database	Data	Critical
E-commerce website	Application	High
25 Windows computers	Hardware	High

Asset	Category	Criticality
Company Wi-Fi/network	Network	High
Administrator account	Privileged account	Critical
Employee accounts	Accounts	High
Cloud file storage	Cloud/Data	Critical
Router/firewall	Network/Security	Critical
CCTV	Physical security	Medium
Customer information	Data	Critical

4. Risk Assessment

The following risk register summarizes the main findings identified during the audit.

#	Asset	Vulnerability	Threat	Likelihood	Impact	Risk
1	Admin account	Weak password; no MFA	Credential attack / unauthorized access	High	High	Critical
2	Windows computers	Unpatched for 8 months	Exploitation of known vulnerabilities	High	High	High
3	Company Wi-Fi	One shared password	Unauthorized or former-user access	Medium	High	High
4	Employee accounts/devices	Phishing susceptibility; controls require review	Credential theft / device compromise	High	High	Critical
5	Customer DB/backups	Only backup on same server	Ransomware, failure, or corruption	High	High	Critical
6	Cloud files	Excessive access permissions	Insider misuse or compromised account	High	High	Critical

Risk 1 - Administrator Account

A weak administrator password combined with the absence of MFA creates a significant privileged-access risk. Because the account has elevated permissions, compromise could expose sensitive systems and enable unauthorized changes.

Risk 2 - Unpatched Windows Computers

Systems that have remained unpatched for eight months may contain known vulnerabilities. Attackers could potentially exploit unpatched weaknesses, so timely patching and ongoing patch management are required.

Risk 3 - Shared Wi-Fi Password

Using one shared Wi-Fi password makes individual access difficult to manage. A former employee or unauthorized person who knows the password may retain network access until the shared credential is changed.

Risk 4 - Phishing

Phishing can be used to steal credentials or compromise employee devices. User awareness and appropriate email/security controls should be reviewed and strengthened.

Risk 5 - Backup Single Point of Failure

Keeping the production database and its only backup on the same server creates a single point of failure. Ransomware, hardware failure, or corruption could affect both the live data and the backup.

Risk 6 - Excessive Cloud Permissions

Employees have access to cloud files beyond their job requirements. This increases the potential impact of accidental actions, insider misuse, or a compromised employee account.

5. Security Controls Assessment

Risk Area	Recommended Controls	Type
Administrator account	Strong password policy; enable MFA	Administrative / Technical
Unpatched Windows	Install missing patches; establish patch-management process	Technical / Administrative
Shared Wi-Fi	Use individual authentication where possible; review/remove access	Technical / Administrative
Phishing	Regular phishing and cybersecurity awareness training; reporting process	Administrative
Database backups	Separate secure backup location; regular backup and recovery testing	Technical / Administrative
Cloud file access	Least privilege; regular permission reviews	Technical / Administrative

Control Rationale

Administrator security: Strong unique passwords reduce password-based attack risk, while MFA adds another authentication factor if a password is exposed.

Patch management: Security updates address known vulnerabilities. A recurring process helps prevent systems from remaining unpatched for long periods.

Network access: Individual authentication improves accountability and makes it possible to revoke one user's access without changing credentials for everyone.

Phishing awareness: Employees should learn to identify suspicious senders, links, attachments, and credential requests, and know how to report suspicious messages.

Backup resilience: A separate backup location reduces the chance that one incident affects both production data and the only recovery copy. Recovery testing verifies that backups are usable.

Least privilege: Employees should receive only the access required for their responsibilities. Regular reviews help remove permissions that are no longer needed.

6. Prioritized Security Recommendations

The following implementation sequence focuses first on high-impact weaknesses and recovery capability. All six items are treated as high implementation priorities in this portfolio exercise.

Order	Recommendation	Reason
1	Secure administrator account with a strong unique password and MFA	Reduces risk around the highest-privilege account.
2	Create a separate secure database backup and test recovery	Reduces the backup single point of failure.
3	Apply least privilege to cloud files and review permissions	Limits unnecessary exposure of sensitive information.
4	Install missing Windows updates and establish patch management	Reduces exposure to known vulnerabilities.
5	Provide regular phishing-awareness training and reporting guidance	Reduces likelihood of successful social-engineering attacks.

Order	Recommendation	Reason
6	Improve Wi-Fi authentication and access management	Makes network access easier to control and revoke.

7. Conclusion

The NovaMart security audit demonstrates how asset identification, risk assessment, security controls, and prioritized recommendations can be combined into a practical cybersecurity review. The audit found that privileged access, backup resilience, excessive permissions, phishing exposure, patching, and Wi-Fi access management require improvement.

Implementing the recommended controls would reduce the identified risks and strengthen the confidentiality, integrity, and availability of NovaMart's systems and information. Security should remain an ongoing process that includes regular patching, access reviews, backup testing, employee awareness activities, and periodic reassessment of risks.

Portfolio Learning Outcomes

This project demonstrates practical understanding of asset classification, threat-vulnerability-risk relationships, qualitative risk rating, the CIA Triad, least privilege, MFA, patch management, backup resilience, phishing awareness, and the distinction between technical and administrative controls.